

Introduction to SIEM

Notes by Imon · September 2026 · github.com/imon333/SOC_Level_1

Task 1 – Introduction

SIEM (Security Information and Event Management) is the main tool a SOC analyst works in. After the EDR room, this one zooms out from a single endpoint to the whole network: every device produces logs, and we need one central place to collect, normalise and correlate them.

What I wanted to get out of this room:

- The different types of log sources
- Why working with isolated logs is a problem
- Why a SIEM is important and what features it has
- How different log sources are ingested into a SIEM
- How alerting works and how an alert is analysed

Task 2 – Logs Everywhere, Answers Nowhere

A normal network has Windows and Linux endpoints, servers, a website, and a router connecting it all to the internet. Every one of these devices keeps generating logs about what happens on it. That makes them **log sources**. Logs are the trail we follow to find malicious activity, and they are also useful for general troubleshooting. Log sources fall into two groups:

	Host-centric	Network-centric
What it captures	Events inside or related to a host	Events when hosts talk to each other or to the internet
Devices	Windows and Linux machines, servers	Firewalls, IDS/IPS, routers
Examples	File access, authentication attempts, process execution, registry key add/edit/delete, PowerShell execution	SSH connections, FTP file access, web traffic, VPN access to company resources, network file sharing

The problem with having logs everywhere

Having logs is one thing, getting answers from them is another. The room listed the main challenges:

- **Too many log sources** – hundreds of events per second, spread across many devices. Checking each device one by one during an incident is slow and painful.
- **No centralisation** – logs stay on the machine that created them, so you would have to SSH or RDP into each one. A huge waste of time in an investigation.
- **Limited context** – a single log rarely tells the whole story. A file access looks normal on its own, but correlated with other sources it might turn out the user reached that machine through lateral movement after compromising another one.
- **Limited analysis** – no human can manually go through that volume of logs. Important events will be missed.

- **Format issues** – every source logs in its own format, and the analyst would need to know all of them.

Room questions

Is registry-related activity host-centric or network-centric?	host-centric
Is VPN-related activity host-centric or network-centric?	network-centric

Task 3 – Why SIEM?

SIEM is the answer to all the problems above. In one sentence: it **collects** logs from all kinds of sources, **standardises** them into one format, **correlates** them, and **detects** malicious activity with detection rules.



Figure 1: The basic SIEM cycle: collect, aggregate, detect, investigate.

Core features

Centralised log collection. Logs from endpoints, servers, firewalls and so on are pulled in through lightweight agents or APIs and stored in one place. No more jumping from machine to machine.

Normalisation. A Windows log looks nothing like a Linux log. Two terms I want to keep apart:

- **Parsing** – breaking one log down into separate fields so it is easier to read.
- **Normalisation** – converting logs from all the different sources into one consistent format.

Correlation. The SIEM looks for relationships between logs from different sources. The room's example, all happening on one system within 5 minutes:

- Haris logs in over VPN from an IP he has never used before
- Haris opens some documents on a shared drive
- Haris runs a PowerShell script
- The system makes an outbound network connection

Each step alone looks fine. Put together, it looks like data exfiltration using Haris's stolen VPN credentials. This is the same idea as in the EDR room, just across the whole network instead of one host.

Real-time alerting. Detection rules decide when an alert fires. A SIEM ships with default rules, and analysts write their own over time to improve detection. When a rule's conditions are met, the analyst is

notified and investigates inside the SIEM.

Dashboards and reporting. After normalisation and ingestion, dashboards turn the data into something actionable. Typical panels: alert highlights, system notifications, health alerts, failed login attempts, ingested event count, triggered rules, top visited domains. Every SIEM has default dashboards and lets you build custom ones.

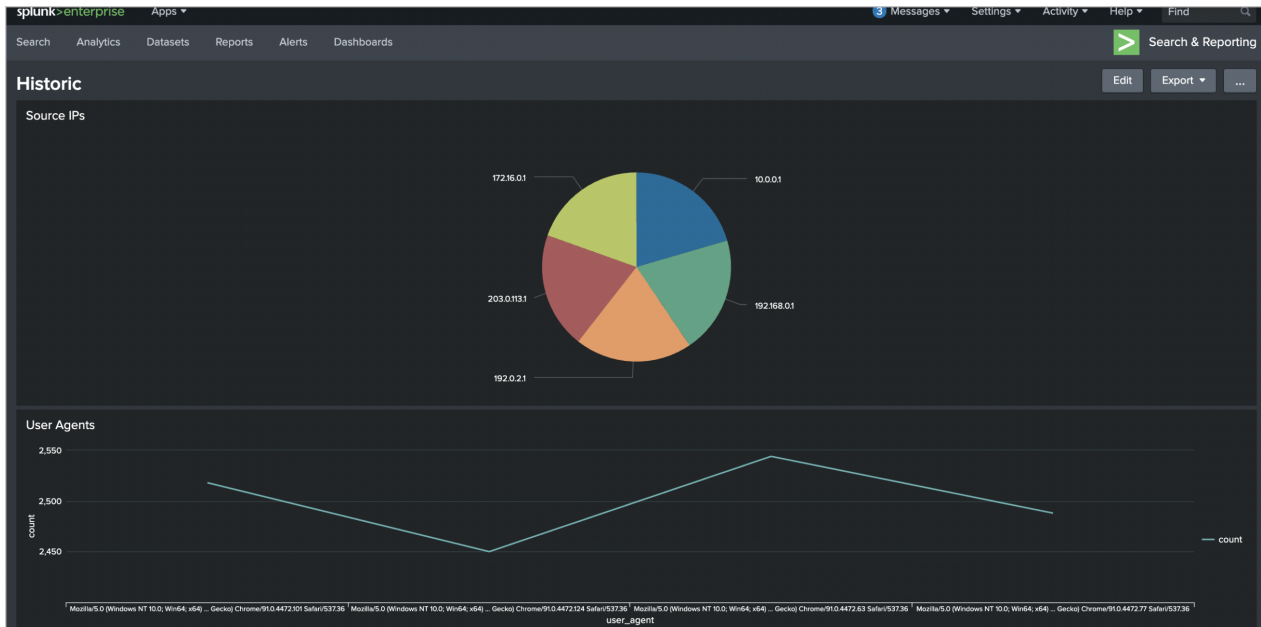


Figure 2: A dashboard in Splunk showing source IPs and user agents.

Other features the room only mentioned: threat intelligence integration, long data retention and powerful search.

Task 4 – Log Sources and Ingestion

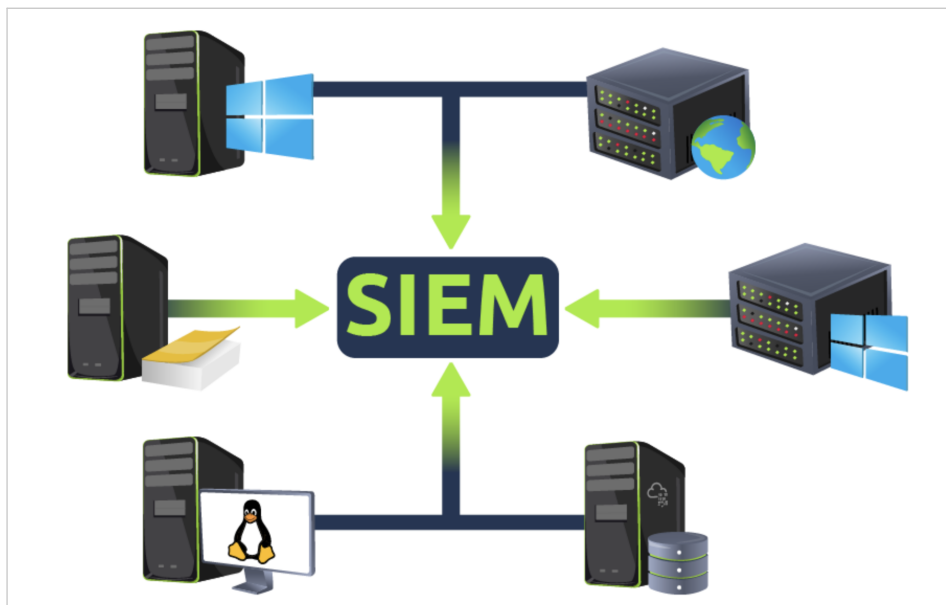


Figure 3: Different hosts and servers all sending their logs into the SIEM.

Windows

Windows records events that can be viewed in **Event Viewer** (just type it into the search bar). Every type of activity has a unique **Event ID**, which makes it easy to track and search for specific events. In a company, logs from all Windows endpoints get forwarded to the SIEM.

Linux

Linux stores events, errors and warnings in log files, which are then ingested into the SIEM. Common locations:

Location	What is stored there
<code>/var/log/httpd</code>	HTTP requests, responses and error logs
<code>/var/log/cron</code>	Cron job events
<code>/var/log/auth.log</code> , <code>/var/log/secure</code>	Authentication logs (auth.log on Debian/Ubuntu, secure on RHEL/CentOS)
<code>/var/log/kern</code>	Kernel events

Side note: the room writes `/var/log/kern`, but on most distributions the actual file is `/var/log/kern.log`.

A sample of cron logs:

```
May 28 13:04:20 ebr crond[2843]: /usr/sbin/crond 4.4 dillon's cron daemon, started with loglevel notice
May 28 13:04:20 ebr crond[2843]: no timestamp found (user root job sys-hourly)
May 28 13:04:20 ebr crond[2843]: no timestamp found (user root job sys-daily)
May 28 13:04:20 ebr crond[2843]: no timestamp found (user root job sys-weekly)
May 28 13:04:20 ebr crond[2843]: no timestamp found (user root job sys-monthly)
Jun 13 07:46:22 ebr crond[3592]: unable to exec /usr/sbin/sendmail: cron output for user root job sys-daily to /dev/null
```

Web server

All requests and responses to a web server should be monitored for web attack attempts. On Linux, Apache logs are usually in `/var/log/apache` or `/var/log/httpd`.

```
192.168.21.200 - - [21/March/2022:10:17:10 -0300] "GET /cgi-bin/try/ HTTP/1.0" 200 3395 "-"
"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/98.0.4758.102 Safari/537.36"
127.0.0.1 - - [21/March/2022:10:22:04 -0300] "GET / HTTP/1.0" 200 2216 "-" "curl/7.68.0"
```

Reading one line from left to right: client IP, timestamp, the request (method, path, protocol), status code, response size in bytes, referrer, and user agent. The second line is interesting because the user agent is curl, meaning a script or command line tool made the request, not a browser.

How logs get into the SIEM

Method	How it works
Agent / Forwarder	A lightweight tool installed on the endpoint captures the important logs and sends them to the SIEM (Splunk calls it a forwarder)
Syslog	Widely used protocol that sends real-time data from systems like web servers and databases to a central destination
Manual upload	Offline data is uploaded for quick analysis (Splunk, ELK). It gets normalised after ingestion
Port-forwarding	The SIEM listens on a port and the endpoints send their data to it

Or get data in with the following methods

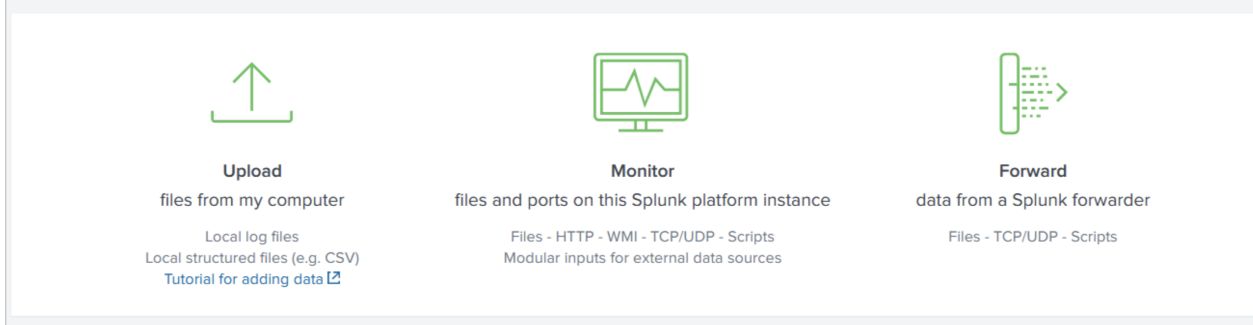


Figure 4: Splunk's data input options: upload, monitor, forward.

Room questions

In which location within a Linux environment are HTTP logs stored? `/var/log/httpd`

Task 5 – Alerting Process and Analysis

Detection rules

Behind every alert is a detection rule, which is basically a logical expression that fires when its conditions are met. Some examples:

- 5 failed logins within 10 seconds → *Multiple Failed Login Attempts*
- Successful login after several failed attempts → *Successful Login After Multiple Login Attempts*
- A USB device is plugged in → alert (useful when USB is restricted by company policy)
- Outbound traffic over 25 MB → possible data exfiltration (threshold depends on company policy)

Building a rule: two use cases

Use case 1: event log cleared. After exploitation, attackers often clear logs to cover their tracks. Clearing event logs generates Event ID 104, so the rule is:

```
IF LogSource = WinEventLog AND EventID = 104
THEN alert "Event Log Cleared"
```

Side note: Event ID 104 comes from the System log. Clearing the Security log creates Event ID 1102 instead, so a real rule should cover both.

Use case 2: whoami execution. Attackers commonly run `whoami` after exploitation or privilege escalation to check who they are running as. Useful fields: the log source, Event ID 4688 (process creation), and `NewProcessName`.

```
IF LogSource = WinEventLog AND EventCode = 4688 AND NewProcessName CONTAINS "whoami"  
THEN alert "WHOAMI command Execution DETECTED"
```

This is why normalisation matters so much: rules watch the values of specific fields. If the logs are not parsed into consistent fields, the rule has nothing reliable to match against.

Investigating an alert

Analysts spend most of their time on dashboards. When an alert fires, they look at the events behind it, check which rule conditions were met, and decide whether it is a true or false positive. Possible next steps:

- **False positive** → may need rule tuning so it doesn't happen again
- **True positive** → investigate further
- Contact the asset owner and ask about the activity
- Suspicious activity confirmed → isolate the infected host
- Block the suspicious IP

Room questions

Which Event ID is generated when event logs are removed?	104
What type of alert may require tuning?	False Positive

Task 6 – Lab Work

The lab is a static SIEM with a dashboard and an event list. After clicking *Start Suspicious Activity*, an alert fires and the job is to walk through it like an analyst: find the event, check the rule, and decide what to do.

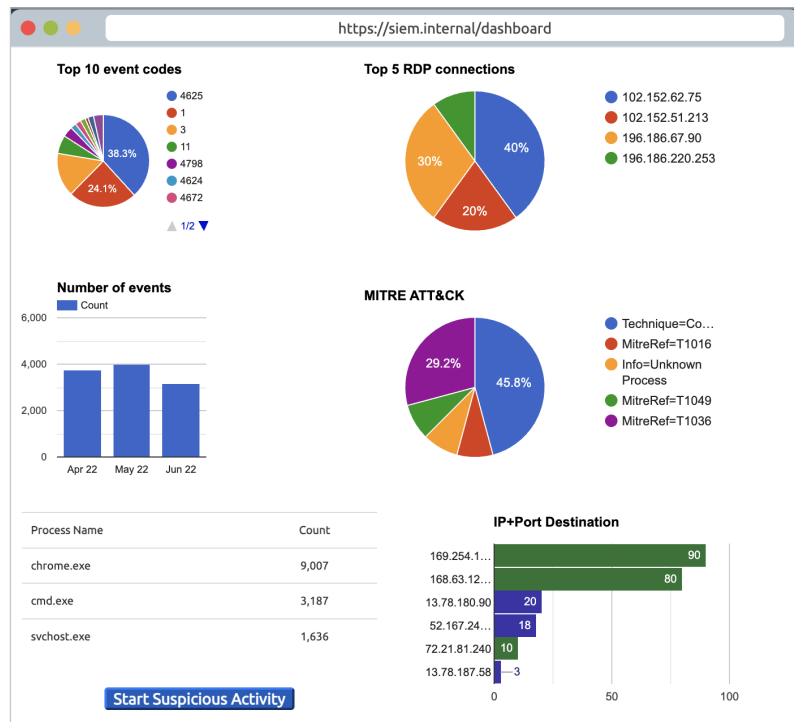


Figure 5: Lab dashboard with top event codes, RDP connections, MITRE mapping and process counts.

Step 1: find the event. All events in the list are Event ID 4688 (process creation) from WindowsEventLogs. Scrolling right to the ProcessName column, most entries are normal software (Edge, Java, Python, QuickTime, Quicken). One stands out immediately:

```
HostName: HR_02 UserName: Chris
ProcessName: C:\Users\Chris\temp\cudominer.exe
```

Two red flags: the name contains "miner", and it runs from a temp folder inside the user profile, which is not where legitimate software is normally installed.

eventType	SourceModuleName	HostName	UserName	ProcessName	Opco
JDIT_SUCCESS	eventlog	HR_01	haroon	C:\Windows\System32\MicrosoftEdgeSH.exe	Info
JDIT_SUCCESS	eventlog	Admin_02	Moin	C:\Program Files (x86)\java\jre1.8.0_181\bin\javaws.exe	Info
JDIT_SUCCESS	eventlog	IT_01	Bell	C:\Python3\python.exe	Info
JDIT_SUCCESS	eventlog	HR_02	Chris	C:\Users\Chris\temp\cudominer.exe	Info
JDIT_SUCCESS	eventlog	IT_02	Amelia	C:\Program Files\QuickTime\quicktime.exe	Info
JDIT_SUCCESS	eventlog	HR_03	Daina	C:\Program Files\Quicken\qw.exe	Info

Figure 6: Event list; cudominer.exe on HR_02 is the odd one out.

Step 2: check the rule.

The rule that fired:

```
Alert "Potential CryptoMiner Activity" IF EventID = 4688
AND Log_Source = WindowsEventLogs AND ProcessName = (*miner* OR *crypt*)
```

cudominer.exe matches the *miner* wildcard. It is a clear match with the use case in Task 5: log source + event ID + a string in the process name.

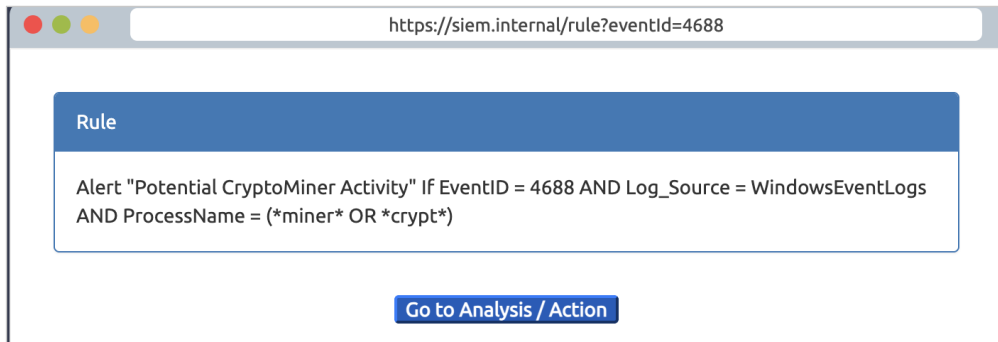


Figure 7: The detection rule behind the alert.

Step 3: decide. An unknown mining binary running from a user's temp folder on an HR machine has no business reason to be there, so this is a **true positive** and the right action is to isolate the host. Selecting that option shows the flag.

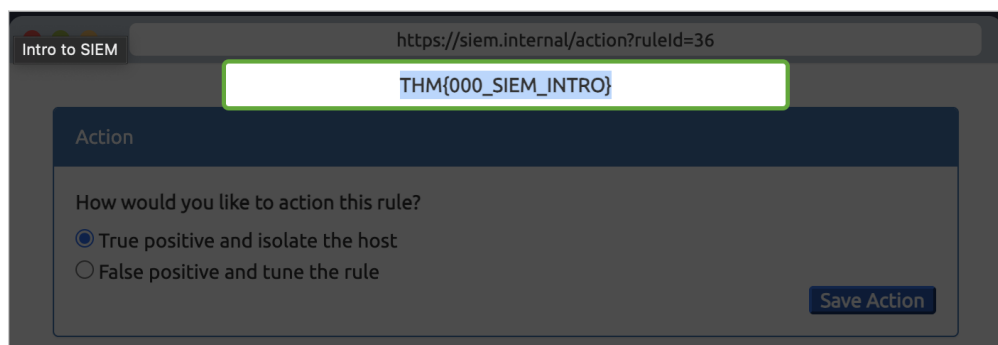


Figure 8: Actioning the alert as a true positive and isolating the host.

Room questions

After clicking Start Suspicious Activity, which process caused the alert?	cudominer.exe
Which user is responsible for the process execution?	Chris
What is the hostname of the suspect user?	HR_02
Which term matched the rule that caused the alert?	miner
Which option best represents the event?	True Positive
What is the flag?	THM{000_SIEM_INTRO}

Task 7 – Conclusion

The room covered what a SIEM is, what it can do and what visibility it gives the SOC. The biggest takeaway for me: logs are only useful once they are in one place, in one format, and correlated. Detection rules are just logic on top of normalised fields, and the analyst's real job starts after the alert fires: finding the event, understanding why the rule matched, and deciding true or false positive.

Rooms suggested for going deeper: Junior Security Analyst Intro, Splunk: The Basics, Incident Handling with Splunk, Benign, Investigating with Splunk, Investigating with ELK, ItsyBitsy.